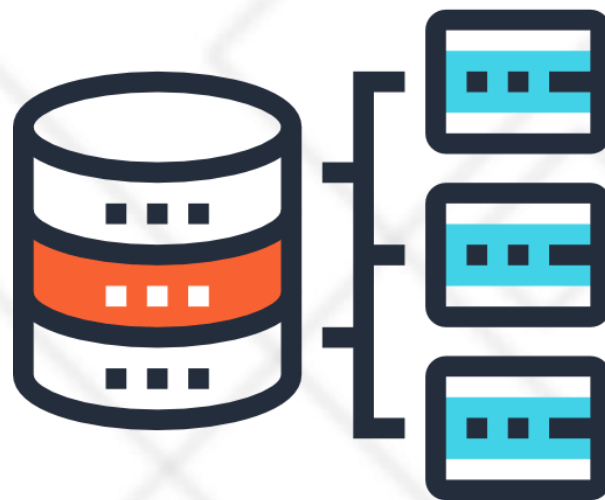




北京理工大学
BEIJING INSTITUTE OF TECHNOLOGY



第6章 数据库的安全性

北京理工大学 计算机学院

段春晖

duanch@bit.edu.cn

第6章 数据库的安全性

□问题的提出

- 数据库的一大特点是数据可以共享
- 但数据共享必然带来数据库的安全性问题
- 数据库系统中的数据共享不能是无条件的共享
 - ◆ 例：军事秘密、 国家机密、 新产品实验数据、
市场需求分析、市场营销策略、销售计划、
客户档案、 医疗档案、 银行储蓄数据
- 数据库中数据的共享是在DBMS统一的严格的控制之下的共享，即只允许有合法使用权限的用户访问允许他存取的数据
- 数据库系统的安全保护措施是否有效是数据库系统主要的性能指标之一

第6章 数据库的安全性

- 安全性对于任何一个数据库管理系统来说都是至关重要的
 - 数据库安全性是保护数据库不被非法使用和防止非法用户恶意造成的破坏
 - 安全性措施的防范对象是非法用户的进入和合法用户的非法操作

- 数据库完整性则是保护数据库以防止合法用户无意造成的破坏
 - 而完整性措施主要防范不合语义的数据进入数据库



第6章 数据库的安全性

- 6.1 计算机安全性概述
- 6.2 数据库安全性概述
- 6.3 用户标识与鉴别
- 6.4 存取控制
- 6.5 视图机制
- 6.6 数据加密
- 6.7 数据库审计
- 6.8 统计数据库的安全性
- 6.9 SQL Server的安全控制

6.1 计算机安全性概述

□什么是计算机系统安全性

- 为计算机系统建立和采取的各种安全保护措施，以保护计算机系统硬件、软件及数据，防止其因偶然或恶意的原因使系统遭到破坏，数据遭到更改或泄露等

□三类计算机系统安全性问题

- **技术安全**指计算机系统中采用具有一定安全性的硬件、软件来实现对计算机系统及其所存数据的安全保护，当计算机系统受到无意或恶意的攻击时仍能保证系统正常运行，保证系统内的数据**不增加、不丢失、不泄露**
- 管理安全
- 政策法律

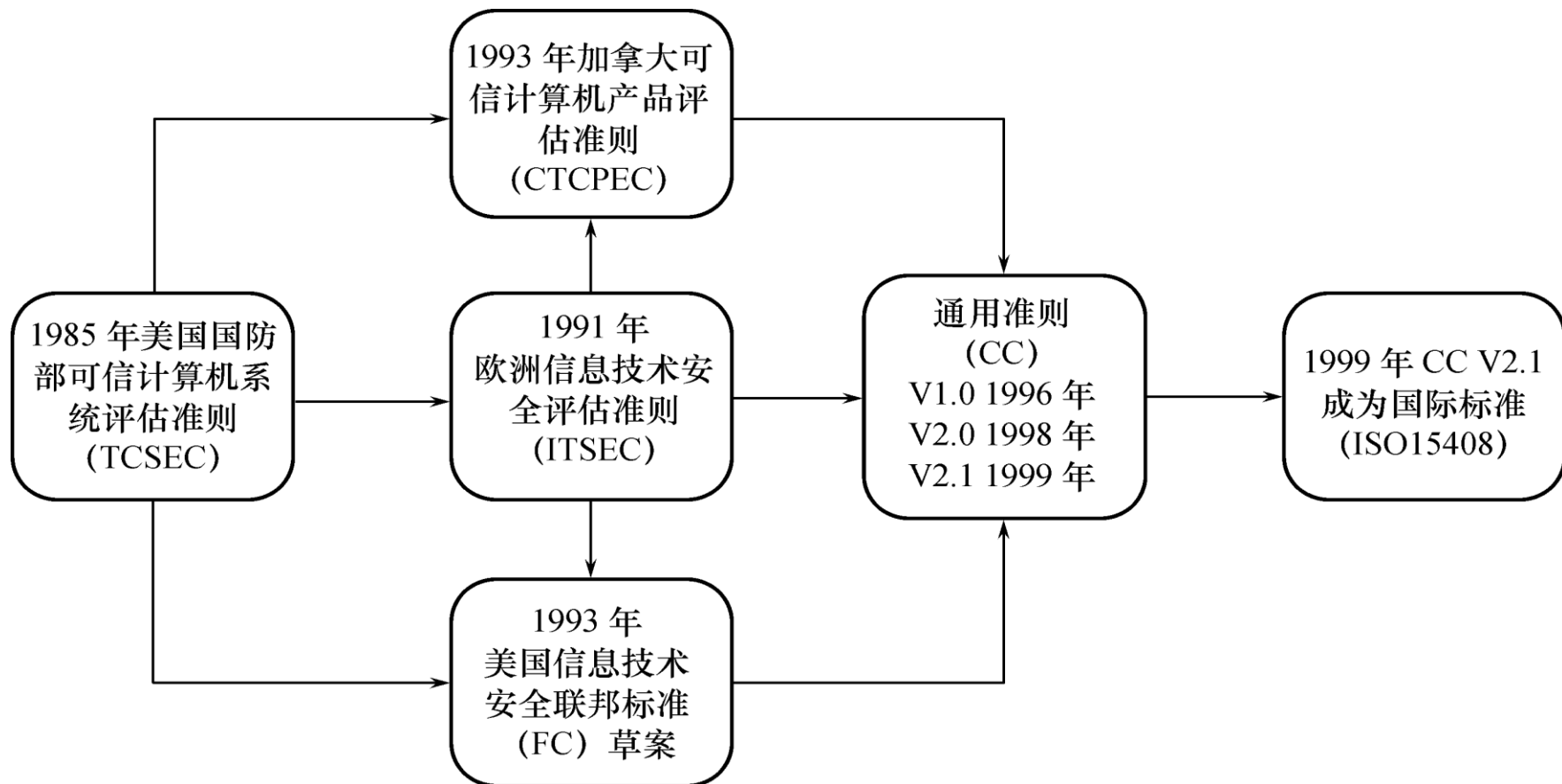
6.1 计算机安全性概述

□可信 (Trusted) 计算机系统的概念和标准

- **TCSEC**是1985年美国国防部 (DoD) 颁布的《DoD可信计算机系统评估标准》，又称桔皮书
- **TDI**将TCSEC扩展到数据库管理系统，定义了数据库管理系统的设计与实现中需要满足和进行安全性级别评估的标准，又称紫皮书
- 在TCSEC推出后的十年里，不同国家都开始启动开发建立在TCSEC概念上的评估准则，这些准则比TCSEC更加灵活。 **CC** (Common Criteria) 项目被发起，主要目的是解决原标准中概念和技术上的差异，将各自独立的准则集成一组单一的、能被广泛使用的IT安全准则

6.1 计算机安全性概述

□信息安全标准的发展历史



6.1 计算机安全性概述

□ TCSEC/TDI标准的基本内容

- TCSEC/TDI从四个方面来描述安全性级别划分的指标
 - ◆ 安全策略
 - ◆ 责任
 - ◆ 保证
 - ◆ 文档

6.1 计算机安全性概述

□ TCSEC/TDI安全级别划分

安全级别	定义
A1	验证设计 (Verified Design)
B3	安全域 (Security Domains)
B2	结构化保护 (Structural Protection)
B1	标记安全保护 (Labeled Security Protection)
C2	受控的存取保护 (Controlled Access Protection)
C1	自主安全保护 (Discretionary Security Protection)
D	最小保护 (Minimal Protection)

6.1 计算机安全性概述

□四组 (division) 七个等级

- D
- C (C1, C2)
- B (B1, B2, B3)
- A (A1)

□按系统可靠或可信程度逐渐增高

□各安全级别之间具有一种偏序向下兼容的关系， 即较高安全性级别提供的安全保护要包含较低级别的所有保护要求，同时提供更多或更完善的保护能力

6.1 计算机安全性概述

□D级

- 将一切不符合更高标准的系统均归于D组
- 典型例子：DOS是安全标准为D的操作系统，DOS在安全性方面几乎没有什么专门的机制来保障

□C1级

- 非常初级的自主安全保护
- 能够实现对用户和数据的分离，进行自主存取控制(DAC)，保护或限制用户权限的传播
- 现有的商业系统稍作改进即可满足C1

6.1 计算机安全性概述

□ C2级

- 安全产品的最低档次
- 提供受控的存取保护，将C1级的DAC进一步细化，以个人身份注册负责，并实施审计和资源隔离
- 达到C2级的产品在其名称中往往不突出“安全”(Security)这一特色
- 典型例子
 - ◆ 操作系统
 - Microsoft的Windows NT 3.5
 - 数字设备公司的Open VMS VAX 6.0和6.1
 - ◆ 数据库：Oracle 7、SQL Server 2000、Sybase 11

6.1 计算机安全性概述

□ B1级

- 标记安全保护。“安全”(Security) 或“可信”(Trusted) 的产品
- 对系统的数据加以标记, 对标记的主体和客体实施强制存取控制 (MAC)、审计等安全机制
- 典型例子
 - ◆ 操作系统
 - 惠普公司的HP-UX BLS release 9.0.9+
 - ◆ 数据库
 - Oracle公司的Trusted Oracle 7
 - Sybase公司的Secure SQL Server version 11.0.6

6.1 计算机安全性概述

□ B2级

- 结构化保护
- 建立形式化的安全策略模型并对系统内的所有主体和客体实施DAC和MAC
- 经过认证的B2级以上的安全系统非常稀少

□ B3级

- 安全域
- 该级的TCB必须满足访问监控器的要求，审计跟踪能力更强，并提供系统恢复过程

□ A1级

- 验证设计，即提供B3级保护的同时给出系统的形式化设计说明和验证以确信各安全保护真正实现



第6章 数据库的安全性

- 6.1 计算机安全性概述
- 6.2 数据库安全性概述
- 6.3 用户标识与鉴别
- 6.4 存取控制
- 6.5 视图机制
- 6.6 数据加密
- 6.7 数据库审计
- 6.8 统计数据库的安全性
- 6.9 SQL Server的安全控制

6.2 数据库安全性概述

□非法使用数据库的情况

- 用户编写一段合法的程序绕过DBMS及其授权机制，通过操作系统直接存取、修改或备份数据库中的数据
- 直接或编写应用程序执行非授权操作
- 通过多次合法查询数据库从中推导出一些保密数据

例：某数据库应用系统禁止查询单个人的工资，但允许查任意一组人的平均工资。用户甲想了解张三的工资：

- ◆ 首先查询包括张三在内的一组人的平均工资
- ◆ 然后查用自己替换张三后这组人的平均工资
- ◆ 从而推导出张三的工资
- 破坏安全性的行为可能是无意的，故意的，恶意的

6.2 数据库安全性概述

□数据库的安全性不是独立的，涉及数据库的安全机制，也涉及到硬件系统、操作系统、网络系统的安全机制：

- (1) 数据库系统层

- ◆ 数据库系统需要保证只允许那些获得授权的用户访问权限范围内的数据，权限范围外的数据不允许访问和修改

- (2) 操作系统层

- ◆ 操作系统有自己的安全保护措施。不管数据库系统多安全，操作系统安全性方面的弱点也会造成数据的不安全隐患

- (3) 网络层

- ◆ 由于几乎所有的数据库系统都允许通过终端或网络进行远程访问，网络层的安全同样需要考虑

6.2 数据库安全性概述

- 数据库系统所采用的安全技术主要包括以下几类
 - (1) **访问控制技术**：防止未授权的人访问系统本身，这种安全问题对所有计算机系统都存在。访问控制技术主要通过创建用户帐户和口令、由DBMS控制登录过程来实现
 - (2) **存取控制技术**：DBMS必须提供相应的技术保证用户只能访问他的权限范围内的数据，而不能访问数据库的其他内容
 - (3) **数据加密技术**：用于保护敏感数据的传输和存储，可以对数据库的敏感数据提供额外的保护
 - (4) **数据库审计**：审计是在数据库系统运行期间，记录数据库的访问情况，以利用审计数据分析数据库是否受到非法存取



第6章 数据库的安全性

- 6.1 计算机安全性概述
- 6.2 数据库安全性概述
- 6.3 用户标识与鉴别
- 6.4 存取控制
- 6.5 视图机制
- 6.6 数据加密
- 6.7 数据库审计
- 6.8 统计数据库的安全性
- 6.9 SQL Server的安全控制

6.3 用户标识与鉴别

□ 用户标识和鉴定是系统提供的最外层安全保护措施，保证数据库安全性的最简单、最基本的措施

□ 基本方法

- 任何对数据库系统的访问都需要通过用户标识来获得授权，拥有数据库登录权限的用户才能进入数据库管理系统
- 常用的方法是采用用户名 (user name) 或用户帐号 (user account)，以及口令 (password) 来标识用户身份

□ 动态口令鉴别

- 口令是**动态变化**的，每次鉴别时均需使用动态产生的新口令登录数据库管理系统，即采用**一次一密**的方法

□ 密码卡、声音、图像、指纹

6.4 存取控制

□存取控制机制的功能

- 数据库安全最重要的是：确保只授权给所有有资格的用户访问数据库的权限，同时令所有未被授权的人员无法接近数据
- 这主要通过数据库系统的存取控制机制实现

6.4 存取控制

□存取控制机制的组成

- 定义用户权限

- ◆ 在数据库系统中，为了保证用户只能访问他有权存取的数据，必须预先对每个用户定义存取权限

- 合法权限检查

- ◆ 对于通过鉴定获得上机权的用户（即合法用户），系统根据他的存取权限定义对他的各种操作请求进行控制，确保他只执行合法操作

□用户权限定义和合法权限检查机制一起组成了DBMS的安全子系统

□当前大型DBMS都支持C2级中的自主存取控制(DAC)，有些DBMS同时还支持B1级中的强制存取控制(MAC)

常用存取控制方法

□ 自主存取控制 (Discretionary Access Control, DAC)

- C2级、灵活
- 同一用户对于不同的数据对象有不同的存取权限
- 不同的用户对同一对象也有不同的权限
- 用户还可将其拥有的存取权限转授给其他用户

□ 强制存取控制 (Mandatory Access Control, MAC)

- B1级、严格
- 每一个数据对象被标以一定的密级
- 每一个用户也被授予某一个级别的许可证
- 对于任意一个对象，只有具有合法许可证的用户才可以存取

6.4.1 自主存取控制

- 通过 SQL 的 **GRANT** 语句和 **REVOKE** 语句实现
- 用户权限组成
 - 数据对象
 - 操作类型
- 定义存取权限称为授权
 - 定义用户可以在哪些数据库对象上进行哪些类型的操作

6.4.1 自主存取控制

□关系数据库系统中存取控制对象

对象类型	对象	操 作 类 型
数据库 模式	模式	CREATE SCHEMA
	基本表	CREATE TABLE, ALTER TABLE
	视图	CREATE VIEW
	索引	CREATE INDEX
数据	基本表和视图	SELECT, INSERT, UPDATE, DELETE, REFERENCES, ALL PRIVILEGES
	属性列	SELECT, INSERT, UPDATE, REFERENCES, ALL PRIVILEGES

6.4.1 自主存取控制

□ 授权粒度

- 授权粒度是指可以定义的数据对象的范围
 - ◆ 它是衡量授权机制是否灵活的一个重要指标
 - ◆ 授权定义中数据对象的粒度越细，即可以定义的数据对象的范围越小，授权子系统就越灵活，但系统定义与权限检查的开销将增加
- 关系数据库中授权的数据对象粒度
 - ◆ 数据库、表、属性列、行
- 能否提供与数据值有关的授权反映了授权子系统精巧程度



数据库角色



- 在用户数量比较大的情况下，为了便于权限管理，需要引入角色的概念
- 数据库角色：被命名的一组与数据库操作相关的权限
 - 角色是权限的集合，可以为一组具有相同权限的用户创建一个角色，简化授权的过程

□(1) 角色的创建

CREATE ROLE <角色名>;

□(2) 给角色授权

**GRANT <权限> [, <权限>]...
ON <对象类型> 对象名
TO <角色> [, <角色>]...;**



□(3) 将一个角色授予其他的角色或用户

GRANT <角色1> [, <角色2>]...

TO <角色3> [, <用户1>]...

[WITH GRANT OPTION];

□(4) 角色权限的收回

REVOKE <权限> [, <权限>]...

ON <对象类型> <对象名>

FROM <角色> [, <角色>]...;

□[例 6-1] 用户Wang通过角色实现将一组权限授予用户Li和Zhao

- 首先, Wang创建一个角色R1:

CREATE ROLE R1;

- Wang授予角色R1拥有下面三个关系的查询权限:

GRANT SELECT

ON TABLE Student, SC, Course

TO R1;

- Wang将角色R1授予用户Li和Zhao, 使他们具有角色R1所包含的全部权限:

GRANT R1

TO Li, Zhao;



权限的传播



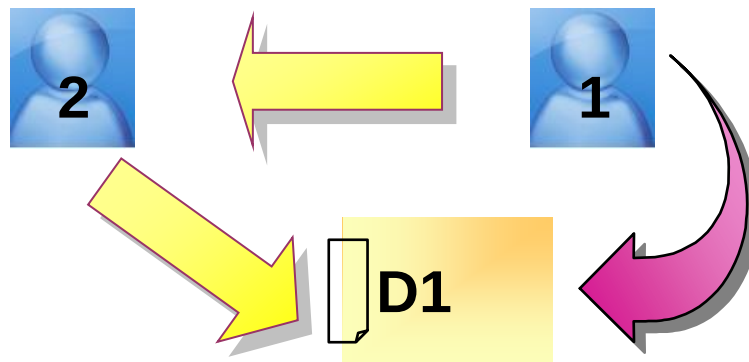
□ SQL灵活的授权机制

- DBA：拥有所有对象的所有权限
 - ◆ 不同的权限授予不同的用户
- 用户：拥有自己建立的对象的全部的操作权限
 - ◆ GRANT：授予其他用户
- 被授权的用户
 - ◆ “继续授权” 许可：再授予
- 所有授予出去的权力在必要时又都可用REVOKE语句收回

□ 这样的存取控制就是自主存取控制

权限的传播

- 自主存取控制优点：能够通过授权机制有效地控制其他用户对敏感数据的存取
- 自主存取控制缺点：
 - 由于存取权限是“自主”的，权限可以传播，接受授权的用户就可以“非法”传播数据，可能存在数据的“无意泄露”



- 原因：这种机制仅仅通过对数据的存取权限来进行安全控制，而数据本身并无安全性标记
- 解决：对系统控制下的所有主客体实施强制存取控制策略

6.4.2 强制存取控制

□什么是强制存取控制

- 强制存取控制 (MAC) 是指系统为保证更高层次的安全性, 按照TDI/TCSEC标准中安全策略的要求, 所采取的强制存取检查手段
- MAC不是用户能直接感知或进行控制的
- MAC适用于对数据有严格而固定密级分类的部门
 - ◆ 军事部门
 - ◆ 政府部门

6.4.2 强制存取控制

□ 主体与客体

- 在MAC中，DBMS所管理的全部实体被分为主体和客体两大类

□ 主体是系统中的活动实体

- DBMS所管理的实际用户
- 代表用户的各进程

□ 客体是系统中的被动实体，是受主体操纵的

- 文件
- 基表
- 索引
- 视图

6.4.2 强制存取控制

强制存取控制策略

- 需要在安全级别基础上对数据或用户进行分类，通过对主体和客体的已分配的安全属性进行匹配判断，决定主体是否有权对客体进行进一步的访问操作
- (1) 主体和客体被标记成不同的安全分类级别

安全分类级别被分为若干级别，典型的级别是：绝密-TS (Top Secret)、机密-S (Secret)、可信-C (Confidential) 和公开 (Public)

 - ◆ 主体的敏感度标记称为**许可证级别** (Clearance Level)
 - ◆ 客体的敏感度标记称为**密级** (Classification Level)
- (2) MAC机制就是通过对比主体的安全级别和客体的安全级别，最终确定主体能否存取客体

6.4.2 强制存取控制

□强制存取控制规则：

- (1) 仅当主体的许可证级别大于或等于客体的密级时，该主体才能读取相应的客体
 - ◆ 许可证级别低的主体不能读取安全级别比他高的客体
- (2) 仅当主体的许可证级别小于等于客体的密级时，该主体才能写相应的客体
 - ◆ 规则2禁止主体写安全分类级别比他的许可证级别低的客体
 - ◆ 如果违反这个规则，那么就将允许信息从较高的安全级别流向较低的安全级别，这就违反了多级安全性的基本原则
 - ◆ 禁止了拥有高许可证级别的主体更新低密级的数据对象，防止敏感数据泄漏

6.4.2 强制存取控制

□强制存取控制的特点

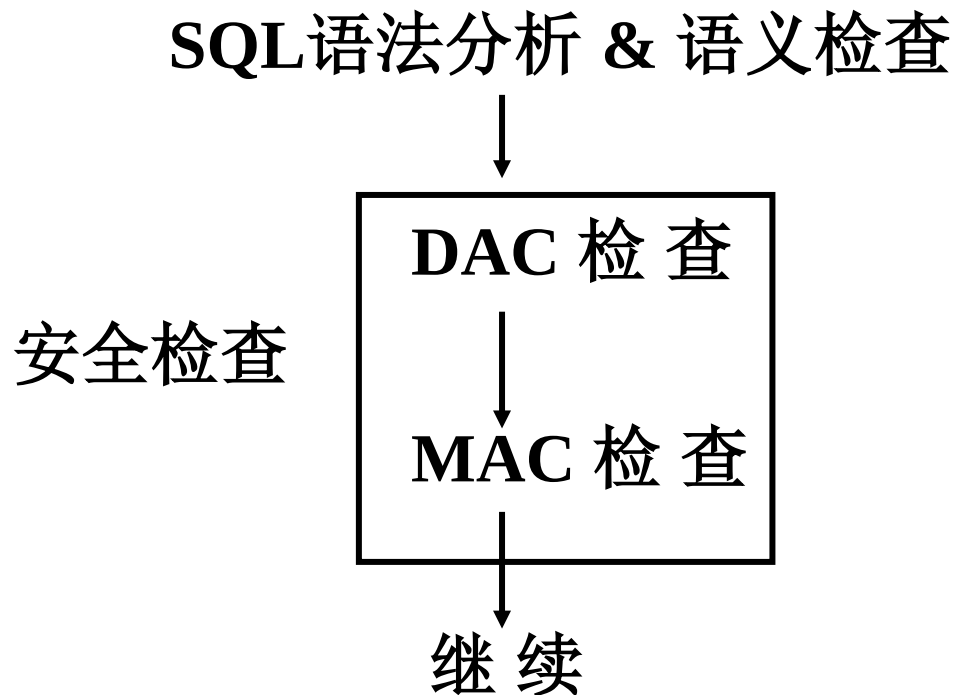
- MAC是对数据本身进行密级标记，无论数据如何复制，标记与数据是一个不可分的整体
- 只有符合密级标记要求的用户才可以操纵数据，从而提供了更高级别的安全性

□MAC与DAC

- DAC与MAC共同构成DBMS的安全机制
- 实现MAC时要首先实现DAC
 - ◆ 原因：较高安全性级别提供的安全保护要包含较低级别的所有保护

6.4.2 强制存取控制

□DAC + MAC安全检查示意图





第6章 数据库的安全性

- 6.1 计算机安全性概述
- 6.2 数据库安全性概述
- 6.3 用户标识与鉴别
- 6.4 存取控制
- 6.5 视图机制
- 6.6 数据加密
- 6.7 数据库审计
- 6.8 统计数据库的安全性
- 6.9 SQL Server的安全控制

6.5 视图机制

- 进行存取权限控制时可以为不同的用户定义不同的视图，把数据对象限制在一定范围内
 - 通过视图机制把要保密的数据对无权存取的用户隐藏起来，从而自动地对数据提供一定程度的保护
 - 视图机制更主要的功能在于提供数据独立性，其安全保护功能并不精细，往往不能达到应用系统的要求
- 视图机制与授权机制配合使用
 - 首先用视图机制屏蔽掉一部分保密数据，视图上面再进一步定义存取权限
 - 间接实现了支持存取谓词的用户权限定义

6.5 视图机制

□[例] 王平只能检索计算机系学生的信息，系主任张明具有增删改查计算机系学生信息的所有权限

- 先建立计算机系学生的视图CS_Student

CREATE VIEW CS_Student

AS SELECT *

FROM Student

WHERE Sdept='CS';

- 在视图上进一步定义存取权限，间接实现了支持存取谓词

GRANT SELECT ON CS_Student TO 王平;

GRANT ALL PRIVILEGES ON CS_Student TO 张明;

□通过视图进行权限管理，可以很容易实现行级或列级的访问控制机制



第6章 数据库的安全性

- 6.1 计算机安全性概述
- 6.2 数据库安全性概述
- 6.3 用户标识与鉴别
- 6.4 存取控制
- 6.5 视图机制
- 6.6 数据加密
- 6.7 数据库审计
- 6.8 统计数据库的安全性
- 6.9 SQL Server的安全控制

6.6 数据加密

- 数据加密：防止数据库中数据在存储和传输中失密的有效手段
- 加密的基本思想
 - 根据一定的算法将原始数据 (术语为明文, Plain text) 转换为不可直接识别的格式 (术语为密文, Cipher text)
 - 不知道解密算法的人无法获知数据的内容
- 加密方法
 - 替换方法：使用密钥 (Encryption Key) 将明文中的每一个字符转换为密文中的一个字符
 - 置换方法：将明文的字符按不同的顺序重新排列
 - 混合方法：美国1977年制定的官方加密标准：数据加密标准 (Data Encryption Standard, 简称DES)

6.6 数据加密

□ DBMS中的数据加密

- 有些数据库产品提供了数据加密例行程序
- 有些数据库产品本身未提供加密程序，但提供了接口

□ 数据加密功能通常也作为可选特征，允许用户自由选择

- 数据加密与解密是比较费时的操作
- 数据加密与解密程序会占用大量系统资源
- 应该只对高度机密的数据加密

第6章 数据库的安全性

- 6.1 计算机安全性概述
- 6.2 数据库安全性概述
- 6.3 用户标识与鉴别
- 6.4 存取控制
- 6.5 视图机制
- 6.6 数据加密
- 6.7 数据库审计
- 6.8 统计数据库的安全性
- 6.9 SQL Server的安全控制

6.7 审计

- 用户标识与鉴别、存取控制仅是安全性标准的一个重要方面
- 为了使DBMS达到一定的安全级别，还需要在其他方面提供相应的支持
 - 例如按照TDI/TCSEC标准中安全策略的要求
- 什么是审计
 - 审计日志 (Audit Log)
 - 将用户对数据库的所有操作记录在上面
 - DBA利用审计日志
 - 找出非法存取数据的人、时间和内容
 - C2以上安全级别的DBMS必须具有

6.7 审计

□ 审计分为

- 用户级审计
 - ◆ 针对自己创建的数据库表或视图进行审计
 - ◆ 记录所有用户对这些表或视图的一切成功和（或）不成功的访问要求以及各种类型的SQL操作
- 系统级审计
 - ◆ DBA设置
 - ◆ 监测成功或失败的登录要求
 - ◆ 监测GRANT和REVOKE操作以及其他数据库级权限下的操作

6.7 审计

□ AUDIT语句：设置审计功能

- **[例]** 对修改SC表结构或修改SC表数据的操作进行审计

**AUDIT ALTER, UPDATE
ON SC;**

□ NOAUDIT语句：取消审计功能

- **[例]** 取消对SC表的一切审计

**NOAUDIT ALTER, UPDATE
ON SC;**

6.7 审计

□ 审计功能的可选性

- 审计很费时间和空间，DBA可以根据应用对安全性的要求，灵活地打开或关闭审计功能

□ 强制性机制：用户识别和鉴定、存取控制、视图

□ 预防监测手段：审计技术



第6章 数据库的安全性

- 6.1 计算机安全性概述
- 6.2 数据库安全性概述
- 6.3 用户标识与鉴别
- 6.4 存取控制
- 6.5 视图机制
- 6.6 数据加密
- 6.7 数据库审计
- 6.8 统计数据库的安全性
- 6.9 SQL Server的安全控制

6.8 统计数据库安全性

□统计数据库的特点

- 允许用户查询聚集类型的信息（例如合计、平均值等）
- 不允许查询单个记录信息

例：允许查询 “程序员的平均工资是多少？”

不允许查询 “程序员张勇的工资？”

□统计数据库中特殊的安全性问题

- 在统计数据库中存在着特殊的安全性问题，即可能存在着隐蔽的信息通道，使得可以从合法的查询中推导出不合法的信息

6.8 统计数据库安全性

□例：下面两个查询都是合法的：

1. 本公司共有多少女高级程序员？
2. 本公司女高级程序员的工资总额是多少？

- 如果第一个查询的结果是“1”，那么第二个查询的结果显然就是这个程序员的工资数

□规则1：任何查询至少要涉及 N (N 足够大) 个以上的记录

6.8 统计数据库安全性

□例：用户A发出下面两个合法查询：

1. 用户A和其他N个程序员的工资总额是多少？
2. 用户B和其他N个程序员的工资总额是多少？

● 若第一个查询的结果是X，第二个查询的结果是Y，由于用户A知道自己的工资是Z，那么他可以计算出用户B的工资= $Y-(X-Z)$

● 原因：两个查询之间有很多重复的数据项

□规则2：任意两个查询的相交数据项不能超过M个

6.8 统计数据库安全性

□可以证明，在上述两条规定下，如果想获知用户B的工资额

A至少需要进行 $1+(N-2)/M$ 次查询

□规则3：任一用户的查询次数不能超过 $1+(N-2)/M$

如果两个用户合作查询就可以使这一规定失效

6.8 统计数据库安全性

□ 还有其他一些方法用于解决统计数据库的安全问题

- 例如“数据污染”，也就是回答查询的时候，提供一些偏离正确值的数据，有意地在统计查询的结果中引入一些误差或“噪音”，使从统计查询的结果中推导出个体信息变得困难，避免数据泄漏
- 这个偏离要在不破坏统计数据的前提下进行

□ 数据库安全机制的设计目标：

- 无论采取什么样的安全机制，都仍然会存在绕过这些机制的途径
- 试图破坏安全的人所花费的代价 $\gg$ 得到的利益



第6章 数据库的安全性

- 6.1 计算机安全性概述
- 6.2 数据库安全性概述
- 6.3 用户标识与鉴别
- 6.4 存取控制
- 6.5 视图机制
- 6.6 数据加密
- 6.7 数据库审计
- 6.8 统计数据库的安全性
- 6.9 SQL Server的安全控制

6.9.1 SQL Server的安全体系结构



□ SQL Server的安全体系结构分为以下4个等级

● 操作系统的安全性

在使用客户机通过网络实现对SQL Server服务器的访问时，用户首先要获得客户计算机操作系统的使用权

● SQL Server的登录安全性

SQL Server的服务器级安全性建立在控制服务器登录账号和密码的基础上。用户在登录时提供的登录账号和密码决定了用户能否获得SQL Server的访问权，以及在访问SQL Server时拥有的权利

6.9.1 SQL Server的安全体系结构



□ SQL Server的安全体系结构分为以下4个等级 (续)

- 数据库的使用安全性

在建立用户的登录账号信息时，SQL Server会提示用户选择默认的数据库，以后用户连接服务器就会自动转到默认的数据库上

- 数据库对象的使用安全性

是核查用户权限的最后一个安全等级，在创建数据库对象时，SQL Server自动把该数据库对象的拥有权赋予该对象的创建者。非数据库拥有者必须获得对指定对象执行特定操作的权限，才能访问数据库中的对象

6.9.4 权限管理

□在SQL Server中，权限分为三种

- (1) 对象权限

- ◆对象权限主要针对数据库中的表、视图和存储过程，决定对这些对象能执行哪些操作

- (2) 语句权限

- ◆语句权限主要指用户是否具有权限来执行某条语句

- (3) 系统权限（隐含权限）

- ◆系统权限控制那些只能由SQL Server预定义的系统角色的成员或数据库对象所有者执行的活动

□可以对对象权限和语句权限进行权限设置

6.9.4 权限管理

语句

CREATE DATABASE

CREATE TABLE

CREATE VIEW

CREATE PROCEDURE

CREATE RULE

CREATE DEFAULT

CREATE FUNCTION

BACKUP DATABASE

BACKUP LOG

对象

SELECT

INSERT

UPDATE

DELETE

REFERENCES

TABLE

VIEW

SELECT

UPDATE

REFERENCES

COLUMN

EXEC

STORED

PROCEDURE

预定义

固定角色

对象所有者

6.9.4 权限管理

□在SQL Server中，使用

- GRANT语句把权限授予某一用户以允许该用户执行针对该对象的操作
- 使用REVOKE语句取消用户对某一对象或语句的权限
- 使用DENY语句是拒绝权限，用来禁止用户对某一对象或语句的权限

□**[例6-7]** 给用户 Mary 和 John 以及 Windows NT 组 Corporate\BobJ 授予多个语句权限。语句如下：

**GRANT CREATE DATABASE, CREATE TABLE
TO Mary, John, [Corporate\BobJ];**

拒绝权限以阻止访问



□[例6-9] 用户 Mary、John 和 Corporate\BobJ 不能使用 CREATE DATABASE 和 CREATE TABLE 语句，除非给他们显式授予权限。语句如下：

**DENY CREATE DATABASE, CREATE TABLE
TO Mary, John, [Corporate\BobJ];**



废除权限



□[例 6-11] 废除已授予用户 Joe 和 Corporate\BobJ 的 CREATE TABLE 权限。语句如下：

REVOKE CREATE TABLE

FROM Joe, [Corporate\BobJ];

- 它删除了允许 Joe 与 Corporate\BobJ 创建表的权限
- 与DENY语句不同，如果已将 CREATE TABLE 权限授予给了包含 Joe 和 Corporate\BobJ 成员的任何角色，那么 Joe 和 Corporate\BobJ 仍可创建表

拒绝权限和废除权限的区别



- 安全主体可以通过两种方式获得权限，第一种方式是直接使用GRANT语句为其授予权限，第二种方式是通过作为角色成员继承角色的权限
- 使用REVOKE语句只能删除安全主体通过第一种方式得到的权限，要想彻底删除安全主体的特定权限必须使用DENY语句
- DENY语句的语法形式与REVOKE语句非常类似

6.10 小结

- 随着计算机网络的发展，数据的共享日益加强，数据的安全保密越来越重要
- DBMS是管理数据的核心，因而其自身必须具有一整套完整而有效的安全性机制
- 《可信计算机系统评测标准》TCSEC/TDI从安全策略、责任、保证和文档四个方面描述了安全性级别的指标
- 目前许多大型DBMS达到了C2级，其安全版本达到了B1级
 - C2级的DBMS必须具有自主存取控制功能和初步的审计功能
 - B1级的DBMS必须具有强制存取控制和增强的审计功能

6.10 小结

□实现数据库系统安全性的技术和方法

- 用户标识和鉴别
- 存取控制技术
- 视图技术
- 审计技术

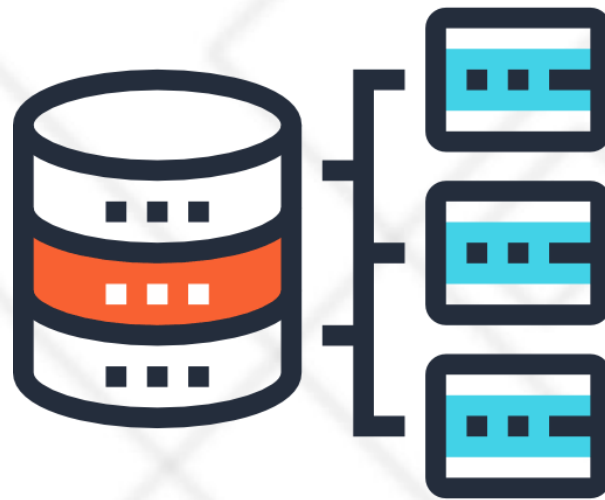
□自主存取控制功能

- 通过SQL的GRANT语句和REVOKE语句实现

□强制存取控制是具有较高安全级别的一种安全控制机制。MAC把用户和数据分为多个安全类别或安全级别，只有符合规定的安全级别的用户才能存取到相关的数据



北京理工大学
BEIJING INSTITUTE OF TECHNOLOGY



作业

《数据库系统原理》第6章

习题1, 2, 3, 4